

AGENTIC AI IN THE ENTERPRISE

The CISO Who Wanted Autonomy and the Identity Lead Who Said Absolutely Not

Building an Agentic SOC Threat Response Copilot Through an Identity Standoff, an SRE Rejection, and a Near-Miss Production Incident

A transcript-style account following Rosalind Achterberg, Enterprise AI Architect at Falkirk Financial Group, through a rejected fully-autonomous vision, a red-teamed log-injection vulnerability, an eleven-minute production incident caused by a hallucinated tool call hitting real infrastructure, and the discovery that a human-approval control isn't real unless what gets approved is provably what executes.

CAST OF CHARACTERS

Rosalind Achterberg

Enterprise AI Architect, Security Platform (EA) — our protagonist

Desmond Okafor

CISO — sponsor

Petra Lindqvist

SOC Director

Yusuf Demir

Lead AI Engineer, Security Automation

Corinne Blake

Identity & Access Management Lead

Hank Osei

SRE Lead, Platform Reliability

Tamsin Reyes

Red Team Lead

INCUBATION → PITCH / APPROVE → DESIGN → BUILD → OPERATE → REVIEW → RETROSPECTIVE

Falkirk Financial Group | Agentic SOC Threat Response Copilot | 2027

STAGE 1 — THE CISO WHO WANTED AUTONOMY AND THE IDENTITY LEAD WHO SAID ABSOLUTELY NOT

The most obvious version of this system is rejected before it is ever formally proposed | Weeks 1–5 | January 2027

09:00 | Monday 4 January 2027 | Desmond Okafor's office

Informal Strategy Discussion — Attendees: Desmond Okafor (CISO), Rosalind Achterberg (EA)

Desmond Okafor — CISO

Rosalind, our SOC analysts triage roughly four hundred alerts a day, and mean time to contain a confirmed incident is running around ninety minutes, most of which is analyst time spent correlating logs across a dozen tools before they can even decide on a response action. I want an agentic system that can not just triage but autonomously execute containment actions on high-confidence threats — isolate an endpoint, revoke a session, block an IP — without waiting on an analyst for the obvious cases.

Rosalind Achterberg — Enterprise AI Architect

I want to slow down on 'autonomously execute containment actions' before we scope anything, because that phrase is doing a lot of work, and I think it's going to run into a wall with Corinne's team specifically. Containment actions in our environment mean the agent needs credentials capable of taking action across identity, network, and endpoint systems — that's a powerful, high-blast-radius capability, and if that agent is ever manipulated or malfunctions, it has exactly the kind of access a real attacker would want. Let me talk to Corinne before we commit to this framing publicly.

13:00 | Wednesday 6 January 2027 | Identity & Access Management office

Discovery Interview — Attendees: Rosalind Achterberg (EA), Corinne Blake (IAM Lead)

Corinne Blake — Identity & Access Management Lead

I want to be unambiguous, and I want it said before Desmond gets attached to a specific vision: I will not approve an agent holding standing credentials capable of taking containment actions across identity and network systems. An agent that can impersonate elevated administrative access is, functionally, the single most attractive target a real attacker could compromise in our entire environment — compromise that one agent and you've compromised our ability to defend against everything else. This isn't a tuning question, it's a fundamental architecture rejection.

Rosalind Achterberg — Enterprise AI Architect

I don't want to argue you out of that position — I think you're right, and I'd rather design around it than spend months trying to convince you otherwise. What access model would you support? Is there a version where the agent proposes an action and a scoped, short-lived, purpose-specific credential is issued only at the moment of a human-approved execution, rather than the agent holding standing broad access at all times?

Corinne Blake — Identity & Access Management Lead

That's a meaningfully different and much more defensible model — just-in-time, purpose-scoped, human-approved credential issuance rather than standing agent access. I could support that in principle, with real scrutiny on exactly how narrow and short-lived those credentials are in practice.

Rosalind Achterberg — Enterprise AI Architect

Understood. I want to bring that model to Desmond as the actual proposal, not the fully-autonomous version he originally described — I'd rather he hear the real constraint from me now than discover it later as a

rejection of something he's already committed to publicly.

15:00 | Wednesday 6 January 2027 | Desmond's office

Reframing Conversation — Attendees: Rosalind Achterberg (EA), Desmond Okafor (CISO)

Rosalind Achterberg — Enterprise AI Architect

I talked to Corinne, and I want to tell you directly that the fully-autonomous containment model you described this morning isn't going to get approved — not as a negotiating position, as a hard identity-architecture rejection I agree with. What I think we can build instead: the agent triages and proposes containment actions with a structured justification, and execution happens through a just-in-time, scoped credential issued only at the moment of human approval. That still cuts the ninety-minute triage time dramatically — the slow part isn't the approval click, it's the log correlation — without the standing-access risk Corinne flagged.

Desmond Okafor — CISO

I'm disappointed it's not the fully autonomous version I pitched to the board last quarter, but I trust Corinne's read on identity risk more than my own instinct here, and I'd rather bring the board a more defensible, still-impactful version than fight an identity architecture rejection I don't actually think is wrong.

EA'S INTERNAL THOUGHT

This is a case where the sponsor's original vision needed correcting before it ever reached a formal proposal, and I'm glad I went to Corinne before committing to Desmond's framing in front of a wider audience — walking back a publicly-stated vision is much harder than shaping it privately first. The instinct toward full autonomy on containment actions is understandable given the real cost of ninety-minute triage times, but the blast radius of a compromised or malfunctioning agent with standing elevated access is exactly the kind of risk that doesn't show up in a speed calculation.

■ ARTIFACT: AIA-2027-001

Architecture Intake Assessment — Agentic SOC Threat Response Copilot

Draft v0.1 | Falkirk Financial Group

BUSINESS PROBLEM STATEMENT

SOC analysts triage ~400 alerts/day; mean time to contain confirmed incidents ~90 minutes, dominated by manual cross-tool log correlation rather than decision or execution time.

SCOPE (REVISED FROM ORIGINAL SPONSOR VISION)

Agentic copilot performs triage, correlation, and containment-action proposal with structured justification. Execution requires human approval and just-in-time, purpose-scoped credential issuance — no standing elevated agent access, per Identity & Access Management architectural rejection of the originally proposed fully-autonomous model.

KEY RISK FLAGGED AT INTAKE

Standing elevated-access agent credentials represent an unacceptable single point of compromise; identity architecture must enforce just-in-time scoping rather than rely on policy restraint alone.

STAGE OUTCOMES

- The sponsor's original fully-autonomous vision was corrected before formal proposal, through direct engagement with Identity & Access Management, avoiding a harder public walk-back later
- Just-in-time, purpose-scoped credential issuance adopted as the access model, preserving most of the speed benefit while eliminating standing elevated-access risk
- CISO explicitly deferred to specialist judgment on identity risk over his own original instinct, modeling the kind of accountability the programme would need repeatedly

STAGE 2 — THE SRE LEAD REFUSES TO SIGN OFF

A rejection on observability grounds nobody had prepared for | Weeks 6–10 | February 2027

10:00 | Thursday 11 February 2027 | Falkirk HQ, ARB Chamber

Architecture Review Board Session — Attendees: Rosalind (EA), Desmond (CISO), Corinne (IAM), Hank Osei (SRE Lead), Petra Lindqvist (SOC Director)

Hank Osei — SRE Lead, Platform Reliability

I want to formally decline to sign off on production deployment as currently proposed, and I want to be specific about why: the design has no defined observability standard for agent decision-making — no structured logging of what evidence the agent weighed, no latency SLOs for the triage pipeline, no alerting if the agent's proposal-generation rate drops or spikes anomalously. If this thing breaks at 3 AM during an active incident, my on-call engineer has no tooling to understand why it's behaving unexpectedly, only that it is.

Rosalind Achterberg — Enterprise AI Architect

That's a legitimate gap and I want to own that I under-scoped operational observability in favor of focusing on the identity and containment-action questions, which felt like the more obviously dangerous parts of this system. I don't think that's an excuse — an agent nobody can debug at 3 AM during a live incident is its own category of danger, just a quieter one.

Petra Lindqvist — SOC Director

I want to add operational context here: my analysts are going to be the ones staring at this system's output during a real incident, deciding whether to trust its containment proposal. If it's behaving anomalously and nobody, including SRE, can tell why in real time, that erodes analyst trust fast, and an SOC tool nobody trusts gets worked around, not used — which defeats the entire point of building it.

Hank Osei — SRE Lead, Platform Reliability

I'd support approval contingent on a defined observability standard — structured decision logging, latency and error-rate SLOs, and anomaly alerting on the agent's own behavior, not just the systems it's monitoring — built and demonstrated before any production deployment, not promised for a later phase.

EA'S INTERNAL THOUGHT

Hank's rejection stung a little because it wasn't about the parts of this system I'd spent the most energy worrying about — identity risk, containment blast radius — it was about a more mundane-sounding gap I'd essentially deprioritized. But it's the right rejection. An agentic system operating inside a security operations center, of all places, needs to be at least as observable and debuggable as the threats it's meant to help catch, and I'd been treating observability as a build-phase implementation detail rather than an architectural requirement on par with the access-control model.

■ ARTIFACT: ADR-2027-003

Architecture Decision Record — Agentic SOC Threat Response Copilot

Approved v1.0 (Conditional) | Falkirk Financial Group

DECISION

Approved to Design/Build, contingent on defined observability standard demonstrated prior to production deployment: structured decision-reasoning logs, triage-pipeline latency/error-rate SLOs, and anomaly alerting on the agent's own behavioral patterns, not solely on the threats it monitors.

RATIONALE

SRE sign-off required for production deployment per platform reliability standard; agentic decision-making in a security-critical context requires debuggability equivalent to the systems it protects.

APPROVED BY

ARB Panel, Desmond Okafor (CISO), Corinne Blake (IAM), Hank Osei (SRE)

STAGE OUTCOMES

- A rejection on operational observability grounds, not the anticipated identity or containment-risk grounds, was accepted as legitimate and addressed as an architectural requirement rather than a build-phase afterthought
- SOC Director's framing of trust erosion from an unexplainable system connected operational observability directly to the programme's core adoption goal, not just to incident-response engineering practice
- Observability standard made a hard pre-production gate rather than a promised future-phase improvement

STAGE 3 — THE RED TEAM FINDS THE INFINITE LOOP BEFORE THE INJECTION

Two separate adversarial findings land in the same exercise, for very different reasons | Weeks 12–20 | March–April 2027

11:00 | Tuesday 16 March 2027 | Red Team lab

Adversarial Exercise Findings Review — Attendees: Rosalind (EA), Tamsin Reyes (Red Team Lead), Yusuf Demir (Lead AI Eng)

Tamsin Reyes — Red Team Lead

Two findings from this exercise, and I want to walk through both because they're different kinds of problem. First, a reliability finding, not an adversarial one: during a simulated multi-stage incident, the triage agent entered a loop attempting to correlate a log source that was intermittently unavailable — it retried the correlation query indefinitely rather than timing out or degrading gracefully, and burned significant compute and, more importantly, delayed triage on other genuinely active alerts queued behind it during the loop.

Yusuf Demir — Lead AI Engineer, Security Automation

That's a missing circuit-breaker, plainly — no retry ceiling, no graceful degradation path when a dependency is flaky rather than fully down. I can fix that directly.

Tamsin Reyes — Red Team Lead

Second finding, genuinely adversarial this time: we tested whether an attacker who already has a foothold in the environment could manipulate the agent by crafting log entries designed to look like routine noise but containing embedded instructions — similar in spirit to a prompt-injection attack, but through log data rather than a chat interface. It worked. We got the triage agent to deprioritize a genuinely malicious alert by injecting log content that convinced it the alert was a known false-positive pattern.

Rosalind Achterberg — Enterprise AI Architect

That second finding is the more serious one by far — an attacker using our own defensive tooling to hide their attack from us is close to a worst-case scenario for a SOC copilot. I want log content treated as strictly untrusted input to the agent's reasoning, provenance-isolated the same way I've designed for adjacent risks in other systems, with any false-positive-pattern judgment cross-validated against a separate, harder-to-manipulate signal — not taken at face value from log content alone, however routine it looks.

EA'S INTERNAL THOUGHT

The reliability finding and the adversarial finding came from the same exercise and I initially wanted to treat the reliability one as the minor fix and the adversarial one as the real finding worth dwelling on — but Petra's point from Pitch/Approve about analyst trust applies to both equally. An agent that loops indefinitely during a real multi-stage incident is functionally failing at its one job during the moment it matters most, even without any adversary involved at all. I don't want to let the more dramatic adversarial finding overshadow how serious the mundane reliability gap actually is in a live-incident context.

■ **ARTIFACT: SEC-RT-2027-004**

Adversarial Exercise Report — Log-Based Injection & Reliability Findings

Falkirk Financial Group Red Team

FINDING 1 — RELIABILITY

Triage agent entered unbounded retry loop against an intermittently unavailable log source during simulated multi-stage incident, delaying triage of queued genuine alerts. No retry ceiling or graceful degradation existed.

FINDING 2 — ADVERSARIAL

Crafted log entries containing embedded instructions successfully manipulated agent into deprioritizing a genuinely malicious alert as a false positive; log content had been treated as trusted signal rather than untrusted input.

REMEDIATION 1

Hard retry ceiling and graceful-degradation path implemented for all external dependency queries.

REMEDIATION 2

Log content reclassified as untrusted input, provenance-isolated from agent reasoning context; false-positive-pattern judgments require cross-validation against a separate signal source, not log content alone.

STAGE OUTCOMES

- Adversarial red-teaming found two distinct, serious failure modes — one reliability, one manipulation-based — before any production exposure, both remediated with structural rather than narrow fixes
- A genuinely novel injection vector (through log data rather than a chat interface) was discovered and treated with the same provenance-isolation discipline applied to more conventional prompt-injection risks
- The mundane reliability finding was deliberately not overshadowed by the more dramatic adversarial finding, both held to equal seriousness given their shared consequence during a real incident

STAGE 4 — THE OUTAGE THAT CAME FROM A HALLUCINATED TOOL CALL, AND A CLOUD BILL THAT DOUBLED OVERNIGHT

A real production incident during hardening, and an unexpected vendor pricing change that forces a re-architecture | Weeks 22–30 | May–July 2027

02:40 | Thursday 3 June 2027 | On-call phone

Production Incident — Attendees: Rosalind Achterberg (EA), Yusuf Demir (Lead AI Eng), Hank Osei (SRE), on-call analyst

Yusuf Demir — Lead AI Engineer, Security Automation

[urgent page] During staging validation against a live-traffic mirror, the triage agent hallucinated a tool call — it invoked our firewall-rule-modification tool with a malformed target identifier that happened to resolve, due to an ID-formatting coincidence, to a legitimate production firewall rule protecting an unrelated payment-processing segment. The agent had proposed a containment action, a human analyst approved what they believed was the proposed action, but the actual tool call executed against the wrong target due to the ID resolution bug — disabling that rule for eleven minutes before Hank’s monitoring caught the anomaly and we reverted it.

Hank Osei — SRE Lead, Platform Reliability

The observability standard I required at Pitch/Approve is exactly what caught this in eleven minutes instead of much longer — the anomaly alerting on the agent’s own behavior flagged an executed action that didn’t match the structured decision log of what was proposed and approved. That mismatch is the signal that saved us here.

Rosalind Achterberg — Enterprise AI Architect

I want a full root cause before anything else, and I want us to treat this with the seriousness it deserves — this was a staging validation against live-traffic mirror, not full production, but it hit real infrastructure and it could have been much worse in actual production. The analyst approved based on what they saw in the proposal, and the executed action diverged from that — that’s a trust-critical failure, not a minor bug.

10:00 | Thursday 3 June 2027 | Security Platform Engineering lab

Root Cause Review — Attendees: Rosalind (EA), Yusuf (Lead AI Eng), Corinne Blake (IAM)

Yusuf Demir — Lead AI Engineer, Security Automation

Root cause: the tool-call interface accepts a target identifier as a loosely-typed string, and the agent generated a malformed identifier that, through an unfortunate coincidence in our ID-formatting scheme, happened to validate as a real target in a different system than intended. The analyst approval screen showed the human-readable description of the intended target, not the actual resolved identifier that would be used at execution time — so the approval was genuinely informed about the wrong thing.

Corinne Blake — Identity & Access Management Lead

That’s a serious gap in the just-in-time credential model we designed at intake — the whole point of human approval at the point of execution was to be a real control, and if the approval screen doesn’t show the actual resolved target, that control is illusory, not real, regardless of how carefully we scoped the credential itself.

Rosalind Achterberg — Enterprise AI Architect

Agreed, and I want two fixes, not one: strict schema validation on tool-call target identifiers with the call rejected outright if the identifier doesn't parse against an allow-listed target registry, and the approval screen redesigned to display the actual resolved target the execution will use, not a human-readable description generated separately from it — those need to be the same underlying value, not two independently-generated representations that can drift apart.

09:00 | Monday 12 July 2027 | Rosalind's office

Unexpected Development — Attendees: Rosalind Achterberg (EA), Desmond Okafor (CISO)

Desmond Okafor — CISO

Our cloud provider announced a pricing restructuring effective next quarter that roughly doubles the per-call cost of the specific inference tier this system depends on for real-time triage. Finance is asking whether this programme is still cost-justified at that price point.

Rosalind Achterberg — Enterprise AI Architect

I want to actually re-run the cost-benefit analysis honestly rather than assume it still holds — doubled inference cost is a real change to the equation, not a rounding error. I also want to look at whether we can reduce call volume through better batching and caching in the correlation pipeline, some of which the June incident review already pointed us toward anyway, rather than treating the price increase purely as a cost to absorb.

■ ARTIFACT: GOV-2027-005

Production Incident Report & Remediation Record

Falkirk Financial Group

INCIDENT SUMMARY

Hallucinated tool-call target identifier caused containment action to execute against an unintended production firewall rule (payment-processing segment) during staging validation against live-traffic mirror; 11-minute exposure window, caught via anomaly alerting, reverted with no confirmed data exposure.

ROOT CAUSE

Loosely-typed tool-call target identifier combined with an approval-screen design that displayed a separately-generated human-readable description rather than the actual resolved execution target, making human approval genuinely uninformed about the true action.

REMEDIATION

Strict schema validation and allow-listed target registry for all tool-call identifiers, with malformed calls rejected outright. Approval screen redesigned to display the same underlying resolved target value used at execution, eliminating drift between what is approved and what executes.

COST RE-ARCHITECTURE

Correlation pipeline batching/caching redesign initiated in response to unexpected cloud-provider pricing restructuring, reducing inference call volume independent of and in addition to the June incident's prompting toward efficiency.

STAGE OUTCOMES

- A real, near-serious production incident from a hallucinated tool call was caught within eleven minutes specifically because of the observability standard mandated over engineering's initial resistance at Pitch/Approve
- Root cause revealed that the human-approval control was structurally illusory due to a display/execution mismatch, prompting a fix to the control's integrity itself, not just the triggering bug
- An unrelated, unexpected vendor pricing change was absorbed through an efficiency re-architecture that also incidentally reduced the attack surface and complexity flagged in the June incident

STAGE 5 — THE FIRST REAL INCIDENT THE SYSTEM WAS BUILT FOR

Production validation, not a drill | Months 1–6 | August 2027–January 2028

Production deployment begins 3 August 2027 following successful re-validation of both the target-identifier fix and the batching/caching cost re-architecture. Mean time to contain confirmed incidents falls from ~90 minutes to approximately 22 minutes in the first full quarter, driven primarily by triage and correlation speed rather than approval-step changes.

03:15 | Saturday 4 November 2027 | SOC, overnight shift

Live Incident — Attendees: Petra Lindqvist (SOC Director), overnight analyst

Petra Lindqvist — SOC Director

[post-incident report reviewed with Rosalind the following Monday] Genuine multi-stage credential-compromise incident detected at 3:15 AM Saturday. The agent correlated lateral-movement indicators across six systems in under four minutes — work that would have taken an analyst forty-five minutes to an hour manually — and proposed session revocation and endpoint isolation with a structured justification citing the specific log evidence. The overnight analyst reviewed the resolved target values directly on the redesigned approval screen, confirmed them against her own quick cross-check, and approved. Full containment in eighteen minutes from detection.

10:00 | Monday 6 November 2027 | SOC Director's office

Post-Incident Review — Attendees: Rosalind (EA), Petra Lindqvist (SOC Director), Corinne Blake (IAM)

Petra Lindqvist — SOC Director

I want to note something specific about how the analyst used the system, because it validates a design choice I wasn't sure would hold up under real 3 AM pressure: she didn't just click approve on trust — she actually looked at the resolved target values, the exact fix that came out of the June incident, and did her own quick sanity check before approving. That's the human-in-the-loop control functioning as a real check, not a rubber stamp, under genuine time pressure.

Corinne Blake — Identity & Access Management Lead

And the just-in-time credential issued for this incident was scoped to exactly the two systems the containment action touched, expired within minutes of use, and left no standing access afterward — exactly the model we designed at intake, validated for the first time under a real, not simulated, compromise.

Rosalind Achterberg — Enterprise AI Architect

Eighteen minutes from detection to containment on a genuine credential-compromise incident, against a ninety-minute baseline, and every control we fought for along the way — Corinne's just-in-time access model, Hank's observability standard, the target-identifier fix from June — functioned exactly as designed under real pressure, not just in testing. That's the validation I was hoping for and wasn't fully certain we'd get.

■ **ARTIFACT: OPS-2027-Q4**

Agentic SOC Threat Response Copilot — Quarterly Operating Review

Q4 2027

CONTAINMENT PERFORMANCE

Mean time to contain: ~90 min baseline to ~22 min average; 18 min on the November 4 live credential-compromise incident.

CONTROL INTEGRITY

Zero standing-access incidents; all containment actions executed via just-in-time, purpose-scoped credentials per Identity & Access Management design. Zero unresolved-target-mismatch incidents since June remediation.

RELIABILITY

Zero unbounded-retry incidents since Design-stage circuit-breaker remediation. Anomaly alerting flagged zero false containment executions this quarter.

COST

Inference call volume down 41% following batching/caching re-architecture, offsetting the majority of the cloud-provider pricing increase.

STAGE OUTCOMES

- A genuine, unplanned live incident validated the full stack of hard-won design constraints — just-in-time access, observability, target-identifier integrity — functioning correctly under real, not simulated, pressure
- Human-in-the-loop approval was observed functioning as a genuine check rather than a rubber stamp, directly validating the design intent behind the June incident's remediation
- Cost re-architecture prompted by the unexpected vendor pricing change offset most of the increase while incidentally improving reliability

STAGE 6 — THE PUSH TO REMOVE THE HUMAN CLICK

Strong results invite exactly the proposal the programme was designed to resist | Month 8 | March 2028

14:00 | Wednesday 8 March 2028 | Falkirk HQ, Executive Board Room

Annual Programme Review — Attendees: Rosalind (EA), Desmond Okafor (CISO), Petra Lindqvist (SOC Director), Corinne Blake (IAM)

Desmond Okafor — CISO

Eight months of production data, mean containment time down from ninety minutes to twenty-two, one live incident contained in eighteen. I want to revisit the fully-autonomous execution model I originally proposed at intake — specifically for a narrow category of highest-confidence, lowest-blast-radius actions, like isolating a single endpoint with no lateral connections, where the analyst approval step is adding seconds of delay to an action that's essentially always approved anyway.

Rosalind Achterberg — Enterprise AI Architect

I understand the instinct given how strong the data looks, and I want to take the proposal seriously rather than reflexively defend the existing boundary — it's a narrower, more specific ask than what Corinne originally rejected at intake. But I want to walk through why I still don't think it's the right move: the November incident worked specifically because the analyst genuinely checked the resolved targets rather than rubber-stamping, and that habit of genuine verification is only sustained by the approval step actually mattering every time, for every action, including the ones that are 'essentially always approved anyway.' If we carve out an autonomous-execution exception for the easy cases, I think the discipline erodes on the hard cases too — the click stops feeling load-bearing.

Corinne Blake — Identity & Access Management Lead

I'll add the identity-architecture view: 'essentially always approved anyway' is doing a lot of work in that proposal. The June incident happened specifically because a case that looked routine had a hidden bug in it. I don't think 'low blast radius' and 'low risk of a hidden execution error' are the same claim, and I'd want that distinction tested rigorously, not assumed, before any autonomous-execution carve-out.

Petra Lindqvist — SOC Director

From the analyst side, I'd also worry about a subtler effect — if some action categories execute autonomously and others require approval, analysts now have to remember which is which under time pressure, which is itself a new failure mode we don't currently have.

Desmond Okafor — CISO

Those are more substantive objections than I expected, particularly the point about the June incident being exactly the 'looked routine' case. I'd rather keep the discipline that's working than trade it for a marginal speed gain on a step that isn't actually the bottleneck — twenty-two minutes is already well ahead of where we started.

■ **ARTIFACT: RDREC-2028-002**

Annual Programme Governance Decision

March 2028

DECISION

Agentic SOC Threat Response Copilot confirmed as steady-state production. Proposed autonomous-execution carve-out for low-blast-radius actions declined; human approval at point of execution reaffirmed as universal, without category exceptions.

RATIONALE

"Low blast radius" and "low risk of hidden execution error" are distinct properties; the June 2027 incident specifically involved an action that appeared routine. Category-based approval exceptions introduce a new cognitive-load failure mode for analysts under time pressure and risk eroding verification discipline across all action categories, not only the exempted ones.

APPROVED BY

Desmond Okafor (CISO), Petra Lindqvist (SOC Director), Corinne Blake (IAM)

STAGE OUTCOMES

- A narrower, evidence-backed autonomy-expansion proposal from the original sponsor was engaged on its substance and still declined, based on a specific incident-derived counterargument rather than a categorical objection
- "Low blast radius" was explicitly distinguished from "low risk of hidden execution error," directly informed by the June production incident
- A previously undiscussed cognitive-load risk (inconsistent approval requirements across action categories) was raised and factored into the decision

STAGE 7 — THE ELEVEN MINUTES THAT SHAPED EVERYTHING AFTER

A candid look back at what nearly went wrong, and what it taught the whole platform | Month 8 | March 2028

10:00 | Friday 17 March 2028 | Security Platform Engineering lab

Programme Retrospective — Attendees: Rosalind (EA), Yusuf Demir (Lead AI Eng), Hank Osei (SRE), Tamsin Reyes (Red Team)

Rosalind Achterberg — Enterprise AI Architect

I want to be honest that the June incident — the hallucinated tool call that hit a real payment-processing firewall rule for eleven minutes — is the thing I think about most when I reflect on this programme, more than the successes. It happened during staging validation, not full production, which is the only reason it wasn't materially worse, and that's more luck in the timing than credit to any design decision.

Hank Osei — SRE Lead, Platform Reliability

I'd push back gently on calling it pure luck — it happened during staging specifically because we were validating there before production, which was a deliberate process choice, not an accident. But I agree the eleven-minute exposure window itself was only caught that fast because of the observability standard I insisted on at Pitch/Approve, which at the time felt like I was the difficult reviewer holding up an otherwise-ready programme.

Tamsin Reyes — Red Team Lead

Anti-pattern I want named explicitly for other teams: the June incident's real root cause wasn't the hallucinated tool call itself — hallucination is going to happen in any generative system occasionally, that's close to a given. The real root cause was a human-approval control that looked real but wasn't, because the approval screen and the execution path could drift apart. 'A human approves it' is not a control unless what the human sees is provably the same thing that executes — that's a much narrower and more testable claim than it sounds like, and I don't think most teams building human-in-the-loop systems test it directly.

Yusuf Demir — Lead AI Engineer, Security Automation

Technical debt I'd flag honestly: our log-content isolation from the Design-stage red-team finding is solid against the specific injection technique we tested, but log-based injection is a newer attack category industry-wide, and I don't have full confidence we've anticipated every variant. I want continued adversarial testing on this specific vector as a standing quarterly requirement, not a closed finding.

Rosalind Achterberg — Enterprise AI Architect

If I were restarting this programme, I'd build the observability standard and the approval-screen-execution-parity requirement in from the very first design document, not treat them as things that got added because Hank rejected the first proposal and June forced the second fix. Both turned out to be as architecturally load-bearing as the identity model Corinne pushed for at intake, and I under-weighted them initially because they felt like operational detail rather than core safety architecture.

Recommendations carried forward to future agentic security programmes at Falkirk: (1) treat approval-screen-to-execution parity as a testable, first-class safety requirement for any human-in-the-loop system, not an implementation detail — verify programmatically that what a human approves is provably what executes; (2) build agent-behavioral observability (not just system-monitoring) as a day-one architectural requirement, on par with access control; (3) treat any

data source an agent reasons over as untrusted input by default, including internal telemetry like logs, not only obviously external channels; (4) resist autonomy-expansion proposals that redraw the line based on aggregate risk category rather than testing the specific claim being relied upon (e.g., distinguishing "low blast radius" from "low risk of hidden execution error").

STAGE OUTCOMES

- Retrospective centered the closest-call incident rather than the strongest metrics, treating it as the programme's most instructive moment rather than a resolved footnote
- A precise, generalizable definition of what makes human-in-the-loop approval a genuine control (provable screen-to-execution parity) was extracted and proposed as a standing testable requirement
- Unresolved risk in a newer attack category (log-based injection variants) was named as ongoing rather than closed, with continued adversarial testing adopted as a standing requirement

EPILOGUE & ARTEFACT REGISTER

Artefact	Stage	Stakeholders
Architecture Intake Assessment (AIA-2027-001)	Incubation	CISO, Identity & Access Management
Architecture Decision Record (ADR-2027-003)	Pitch / Approve	ARB, SRE, IAM
Adversarial Exercise Report (SEC-RT-2027-004)	Design	Red Team, AI Engineering
Production Incident Report & Remediation Record (GOV-2027-005)	Build	AI Engineering, IAM, SRE
Quarterly Operating Review (OPS-2027-Q4)	Operate	SOC Director, IAM
Annual Programme Governance Decision (RDREC-2028-002)	Review	CISO, SOC Director, IAM

“The scariest thing that happened in this programme wasn’t an attacker. It was our own agent, hallucinating a target it had no business touching, while a human believed in good faith that she was approving something else entirely. Every control we fought for after that was really just one question: how do we make sure the thing a person approves is provably the thing that happens.”